

DORA Capstone Scenario

Cloud-Hosted Instant Payment Platform — AWS Environment

Musterbank GmbH · Critical or Important Function (CIF) · Concentration Risk Declared

Prepared by: Shingirai Marenga | ISO 27001 Lead Auditor | CISM | CISSP | ICT Risk Management Professional | Regulatory context: DORA (EU 2022/2554), BAIT, MaRisk, §25b KWG | June 2026

Scenario Overview

Musterbank GmbH, a BaFin-regulated credit institution, is launching a new cloud-hosted instant payment platform to meet PSD2 SEPA Instant requirements. The platform is fully hosted on Amazon Web Services (AWS) in the EU (Frankfurt) region (eu-central-1) and will process retail and SME payment transactions 24/7. As ICT Risk Officer, I am required to demonstrate that the full DORA ICT risk management framework — including all applicable RTS and ITS obligations — has been applied before go-live. This document is consistent with the Musterbank ICT Risk Register (June 2026) and the DORA Gap Analysis (June 2026).

AWS Environment Note: All compute, storage, networking, identity and key management services referenced in this document are deployed on AWS (eu-central-1 primary; eu-west-1 secondary DR region). AWS is the sole cloud service provider. This creates a concentration risk that is formally declared in Section 6 and cross-referenced to Risk Register R-003 (Gross Risk 25 — Critical; CE 25%).

1. CIF Classification

Art. 6(1) | Art. 3(22) DORA | BAIT §2 | §25b KWG

The first governance obligation is to formally determine whether the payment platform meets the threshold for a Critical or Important Function (CIF). Under DORA Article 3(22), a function is critical or important when its disruption would materially impair financial performance, service continuity, or compliance with regulatory obligations. Three criteria are assessed against the RTS on the ICT risk management framework (Mandate #1):

CIF Criterion	Assessment	Outcome
Customer-facing revenue generation	Platform processes 100% of Musterbank retail and SME payment transactions via AWS; no manual fallback channel exists for SEPA Instant.	✓ Meets threshold
Regulatory continuity (§25b KWG / BAIT §2)	AWS outage triggers a reportable incident under BAIT §25(1), MaRisk AT 7.2, and a potential DORA Art.19 major incident notification obligation.	✓ Meets threshold
Reputational and systemic impact	Prolonged AWS outage causes customer-visible payment failures and triggers BaFin notification under Art. 19 DORA; reputational and contractual penalty exposure.	✓ Meets threshold

Governance action: CIF classification documented in the Musterbank CIF-Register (CIF-REF: MB-CIF-2026-001), signed off by the CRO and IT Risk Committee. Entry added to the DORA Register of Information (Art. 28(3)) identifying AWS as the supporting ICT TPP. Under BAIT §2, classification triggers heightened IT oversight for all material outsourcing. AWS is designated a Critical ICT Third-Party Provider (CTPP) and entered in the Auslagerungsregister per §25b KWG with risk classification *wesentlich*.

2. ICT Asset Inventory & Dependency Mapping

Art. 8 DORA | BAIT §4 | RTS Mandate #1 | ITS Mandate #8

DORA Article 8 and the RTS on the ICT risk management framework require a continuously maintained, criticality-classified inventory of all ICT assets supporting the CIF. The inventory is structured by layer and maps to the DORA Register of Information (ITS Mandate #8). All infrastructure components are AWS-native services deployed in eu-central-1 (primary) with DR failover to eu-west-1.

Asset Layer	AWS Services / Components	Criticality	Owner
Application	Payment core engine (EC2 / ECS Fargate); API Gateway (AWS API GW); fraud detection module (Lambda + SageMaker); transaction ledger (RDS PostgreSQL Multi-AZ)	Critical	Musterbank IT
Platform (AWS CSP)	EC2 / ECS compute (eu-central-1); S3 object storage (versioning + replication to eu-west-1); AWS KMS (HSM-backed key management); Elastic Kubernetes Service (EKS); AWS Secrets Manager	Critical	AWS — SLA 99.99%
Network	AWS Direct Connect (dedicated 1 Gbps to Musterbank DC); VPC with private subnets; AWS Transit Gateway; Route 53 DNS; CloudFront CDN; AWS Shield Advanced (DDoS)	Critical	AWS / Musterbank shared
Identity & Access	AWS IAM (RBAC least-privilege); AWS IAM Identity Center (SSO); CyberArk PAM integrated via SAML; AWS MFA (hardware tokens — YubiKey); CloudTrail audit logging for all IAM events	Critical	IT Security
Monitoring & Detection	AWS CloudWatch (metrics + alarms); AWS GuardDuty (threat detection); AWS Security Hub (compliance posture); Splunk SIEM (CloudWatch Logs forwarded); AWS Config (configuration compliance); VPC Flow Logs	Important	SOC / IT Ops
Data	RDS PostgreSQL Multi-AZ (eu-central-1, EU data residency confirmed); S3 encrypted backups (AES-256, SSE-KMS); DynamoDB (session/audit log store); AWS Backup (automated daily snapshots + cross-region copy to eu-west-1)	Critical	Data Management

External Dependencies	SEPA clearing: Deutsche Bundesbank TARGET2 (via AWS Direct Connect VPN); SWIFT Alliance Gateway (on-premise, MFA-enforced); Four-eyes authorisation service (Musterbank-hosted)	Critical	Third parties
------------------------------	---	-----------------	---------------

Concentration Risk (R-003): The entire payment platform — compute, storage, network, identity and key management — runs on a single cloud provider (AWS eu-central-1). This constitutes a concentration risk under DORA Art. 29 and BaFin cloud outsourcing Merkblatt. A formal concentration risk statement is submitted to BaFin (see Section 6). Consistent with ICT Risk Register R-003 (Gross Risk 25 — Critical; CE 25%).

3. Protective Controls

Art. 9–10 DORA | BAIT §6–§8 | RTS
Mandate #1

Article 9 of DORA and the ICT risk management RTS require protection and prevention measures proportionate to the CIF risk profile. All controls are implemented using native AWS security services alongside Musterbank-managed tooling. Controls map to the RTS lifecycle domains: Govern, Identify, Protect, Detect, Respond, Recover.

Control Domain	AWS Service / Control Implemented	DORA / BAIT Ref	Status
Identity & Access (IAM)	AWS IAM RBAC (least-privilege, no wildcard policies); IAM Identity Center (SSO); CyberArk PAM for privileged admin accounts (88% coverage — 100% target by go-live); YubiKey hardware MFA for all payment system access; quarterly access recertification via AWS IAM Access Analyzer; CloudTrail immutable audit log of all API calls	Art. 9(2) BAIT §6	■ Partial (PAM 88%)
Cryptography & Key Management	TLS 1.3 enforced in transit (ALB + API Gateway policies); AES-256 SSE-KMS at rest (S3, RDS, EBS, DynamoDB); AWS KMS HSM-backed CMKs (FIPS 140-2 validated); KMS key rotation: annual automatic rotation enabled; AWS Secrets Manager for credentials — no hardcoded secrets; CloudHSM evaluated for highest-sensitivity key material	Art. 9(3) BAIT §8(4)	✓ Complete
Network Isolation	Payment platform in isolated VPC (eu-central-1); private subnets only — no direct internet egress; AWS WAF (OWASP Top 10 rule set + custom payment API rules); AWS Shield Advanced (DDoS scrubbing, 24/7 AWS DDoS Response Team); Security Groups + NACLs (deny-by-default); VPC Flow Logs → Splunk SIEM; AWS Network Firewall at perimeter; AWS Direct Connect (private 1 Gbps — no public internet path to core services)	Art. 9(2) BAIT §7	✓ Complete
Vulnerability Management	Amazon Inspector (continuous EC2 + container vulnerability assessment); AWS Systems Manager Patch Manager (automated patching — critical CVEs within 72h); Prowler / AWS Security Hub (CIS AWS Foundations Benchmark); DAST: Burp Suite Enterprise in CI/CD pipeline (74% coverage — pre-go-live target ≥90%); Annual external penetration test (scope: AWS perimeter, API Gateway, payment API)	Art. 10 BAIT §8(3)	■ Partial (DAST 74%)
Logging & Detection	AWS CloudTrail (all API activity, immutable S3 log archive); AWS CloudWatch (metric alarms — latency, error rate, availability); AWS GuardDuty (ML-based threat detection — enabled across all accounts); AWS Config (continuous compliance rules — 47 rules enabled); Splunk SIEM integration via Kinesis Data Firehose; SOC monitoring 24/7 with 15-min alert-to-action SLA	Art. 9 BAIT §8	✓ Complete
Data Protection & Privacy	All RDS and S3 data encrypted at rest (SSE-KMS); EU data residency confirmed — eu-central-1 only (S3 Block Public Access enabled; S3 Object Lock for audit logs); dev/test environments: payment data masking in progress (partial gap — TREAT item); DSGVO Art. 32 technical measures documented	Art. 9(3) DSGVO Art.32	■ Partial (Dev/Test gap)

4. Business Impact Analysis – RTO / RPO

Art. 11(6) DORA | MaRisk AT 7.3 | BAIT §9

A Business Impact Analysis was conducted by Business Continuity Management in coordination with IT Risk. The BIA quantified financial, regulatory and reputational impact across three AWS outage duration scenarios, anchored to SEPA Instant Credit Transfer rules and the DORA Art. 19 major incident notification threshold.

Metric	Approved Value	Justification
Recovery Time Objective (RTO)	1 hour	SEPA Instant Credit Transfer rules require settlement within 10 seconds; AWS region failover to eu-west-1 triggers at 15 minutes downtime; RTO validated via semi-annual DR failover test.
Recovery Point Objective (RPO)	5 minutes	RDS Multi-AZ synchronous replication provides near-zero RPO; AWS Backup cross-region snapshots every 5 minutes for transaction DB; no more than 5 minutes of payment data loss tolerable without reconciliation failure.
Maximum Tolerable Period of Disruption (MTPD)	4 hours	Beyond 4 hours, reputational damage, SEPA scheme penalties, BaFin supervisory escalation and Art. 19 DORA major incident reporting become unavoidable.

5. Continuity and Recovery Planning

Art. 11 DORA | BAIT §9 | MaRisk AT 7.3 | ISO 22301

Musterbank's BCM framework is aligned to ISO 22301 and MaRisk AT 7.3. For the AWS-hosted payment platform, three plan types are maintained. AWS region failover (eu-central-1 → eu-west-1) is the primary recovery mechanism for cloud outage scenarios.

Plan	Key Elements	Test Frequency
Business Continuity Plan (BCP)	- Crisis escalation tree: IT Risk → CRO → Management Board - Customer communication templates (BaFin Art. 19 notifiable language) - Manual fallback: SEPA batch processing via domestic correspondent bank - RACI matrix; AWS Incident Manager runbook integrated - BaFin notification workflow: automated trigger at DORA major incident threshold	Annual tabletop + quarterly review
Disaster Recovery Plan (DRP)	- AWS active/passive failover: eu-central-1 (primary) → eu-west-1 (DR) - Automated failover trigger: Route 53 health checks; 15-min downtime threshold - RDS read-replica promotion in eu-west-1 (target: <5 min) - AWS Elastic Disaster Recovery (CloudEndure) for EC2 workloads - Backup restoration runbook: AWS Backup + S3 cross-region restore - Post-recovery reconciliation procedure (RPO validation via CloudWatch)	Semi-annual technical DR test
Exit Plan (Auslagerungsregister)	- Documented AWS-to-alternative-CSP migration path (12-month runway) - Data portability: S3 export + RDS snapshot portability confirmed - Interim operating model during transition to alternative provider - Exit plan referenced in Auslagerungsregister per §25b KWG - Annual board review — consistent with Gap Analysis Art. 28(7) finding	Annual review (§25b KWG)

6. ICT Third-Party Risk – AWS as Critical ICT TPP

Art. 28–30 DORA | §25b KWG | BAIT §9–§10
| RTS Mandates #7, #9 | ITS Mandate #8

Because the payment platform is fully hosted on AWS, Amazon Web Services EMEA SARL is a Critical ICT Third-Party Service Provider (CTPP) under DORA Art. 28. This triggers the full set of enhanced third-party risk management obligations under DORA and §25b KWG, beyond standard outsourcing governance. The RTS on the policy on ICT services supporting critical functions (Mandate #7) and the RTS on subcontracting (Mandate #9) both apply.

6a — Pre-Contract Due Diligence & Ongoing Monitoring (Art. 28(4), 28(6))

Obligation	Musterbank Action
Pre-contract due diligence (Art. 28(4))	Security posture review: AWS ISO 27001, SOC 2 Type II, PCI DSS, CSA STAR Level 2 certificates reviewed; financial stability confirmed (public entity — Amazon.com Inc.); sub-processor mapping obtained (AWS uses sub-processors for CDN, DNS, DDoS — documented); EU data residency confirmed: eu-central-1 data does not leave EU without explicit consent; AWS Shared Responsibility Model documented and accepted.
Ongoing monitoring (Art. 28(6))	Annual AWS security posture review (SOC 2 Type II re-certification checked); AWS Service Health Dashboard monitored daily; quarterly CSP service reports reviewed by IT Risk; AWS Trusted Advisor findings reviewed monthly; concentration risk reported to Risk Committee annually.
Auslagerungsregister (§25b KWG)	Entry created: AWS EMEA SARL — service description (IaaS/PaaS/cloud infrastructure); CIF linkage (MB-CIF-2026-001); risk classification: <i>wesentlich</i> ; contract dates; exit plan reference; BaFin-reportable flag: Yes; concentration risk flag: Yes (70% of critical ICT services on single provider).
Register of Information (Art. 28(3), ITS Mandate #8)	AWS entry added to DORA Register of Information per EBA ITS RTS template: provider identified by LEI; services classified; CIF linkage documented; sub-outsourcing chain (CDN, DNS, DDoS sub-processors) mapped; substitutability and exit arrangement fields completed. Register submitted to BaFin by 30 April 2025 deadline.

6b — Article 30 Mandatory Contractual Content (Art. 28(5)–(9), Art. 30)

DORA Article 30 specifies the mandatory clauses that every contract for ICT services supporting a critical or important function must contain. The RTS on subcontracting (Mandate #9) extends these obligations through the sub-processor chain. All clauses below are verified in the Musterbank–AWS Enterprise Agreement and AWS Data Processing Addendum (DPA):

Art. 30 Mandatory Clause	Musterbank–AWS Implementation	Status
Clear description of services, service levels and data locations (Art. 30(2)(a))	AWS Enterprise Agreement schedules: compute (EC2/ECS), storage (S3/RDS), network (VPC/Direct Connect), security (KMS/GuardDuty/WAF). SLA: 99.99% for EC2 + RDS Multi-AZ. Data location: eu-central-1 explicitly stated; S3 bucket policies enforce EU residency.	✓ Met
Availability, continuity and performance obligations (Art. 30(2)(b))	AWS SLA: 99.99% monthly uptime for EC2 (Multi-AZ); 99.95% for RDS Multi-AZ; 99.99% for S3. Downtime credits contractually enforceable. Incident notification within 4 hours (aligned to DORA Art. 19 threshold) included in DPA.	✓ Met
Security — confidentiality, integrity, availability (Art. 30(2)(c))	AWS Shared Responsibility Model documented: AWS responsible for infrastructure security; Musterbank responsible for data, IAM, application security. AWS commits to ISO 27001, SOC 2 Type II, PCI DSS Level 1, GDPR/DSGVO compliance. Encryption obligations and key management documented in DPA.	✓ Met
Assistance with incident management (Art. 30(2)(d))	AWS Business Support (24/7 — included in Enterprise Agreement); AWS Security Incident Response: dedicated team for confirmed security events; AWS DDoS Response Team (DRT): 24/7 engagement for Shield Advanced customers; Forensic support (AWS artefact access) at no additional charge during incidents.	✓ Met

Audit and inspection rights — entity and supervisors (Art. 30(2)(e))	AWS Enterprise Agreement grants Musterbank: access to AWS Artifact (SOC reports, ISO certificates); right to conduct audits (with notice) or commission third-party audits; BaFin and ECB supervisory access rights explicitly included (DORA Art. 30(2)(e) clause); audit rights extend to relevant sub-processors (CDN, DNS, DDoS providers) per Mandate #9.	✓ Met
Subcontracting conditions and notification of changes (Art. 30(2)(f), RTS Mandate #9)	AWS sub-processor list (CDN: CloudFront; DNS: Route 53; DDoS: AWS Shield sub-processors) contractually listed; material changes notified to Musterbank with 30-day notice; Musterbank retains right to object or exit on material sub-processor changes; audit rights extend through sub-processor chain per RTS Mandate #9.	✓ Met
Termination rights and exit assistance (Art. 30(2)(g))	Termination for convenience: 30-day notice (Musterbank); termination for material breach: immediate; exit assistance: AWS commits to 12-month transition support post-termination; data deletion/export: S3 export tools + RDS snapshot export provided; data deletion certificate issued within 60 days of termination.	✓ Met
Cooperation with supervisors and CTPP oversight (Art. 30(2)(h))	AWS cooperates with the DORA Oversight Framework (EBA Lead Overseer if designated as CTPP); Musterbank must factor Lead Overseer recommendations on AWS into its own risk decisions; supervisory information requests: AWS contractually committed to respond within 10 business days.	✓ Met

6c — AWS Concentration Risk Declaration (Art. 29 DORA | BaFin Cloud Merkblatt)

Concentration Risk — R-003 (ICT Risk Register): AWS hosts 70% of Musterbank's critical ICT services. This exceeds the DORA Art. 29 concentration risk guidance threshold. A formal concentration risk statement has been submitted to BaFin per the BaFin cloud outsourcing Merkblatt. Mitigation: multi-cloud roadmap initiated (Azure EU pilot — Q3 2026); target: reduce single-provider concentration to ≤55% by end 2027. Risk Register R-003: Gross 25 — Critical; CE 25% (exit plan Phase 1 only; Art. 30 clauses 60% complete). Concentration risk reported to Risk Committee annually.

7. Resilience Testing Programme

Art. 24–27 DORA | BAIT §8(3) | RTS
Mandate #6 | TIBER-EU

Articles 24–27 require all CIF-supporting systems to be included in the annual Digital Operational Resilience Testing (DORT) programme. All tests below are scoped to the AWS environment. TLPT applies if Musterbank meets the Art. 26 significance thresholds (to be confirmed with BaFin — currently assessed as likely applicable given payment CIF status).

Test Type	AWS Scope	Frequency	Outcome Measure
Vulnerability Assessment (Amazon Inspector)	EC2 instances, ECS containers, Lambda functions, IAM policy analysis; AWS Config rules compliance; Security Hub findings review	Continuous + quarterly review	Zero critical open > 30 days; Security Hub score ≥90%
Penetration Test (external provider)	AWS perimeter (Internet-facing ALB, API Gateway, CloudFront); payment API business logic; IAM misconfiguration; S3 bucket access controls; VPC network segmentation	Annual	No high/critical unmitigated findings at sign-off
DR Failover Test (AWS → eu-west-1)	Route 53 failover: eu-central-1 → eu-west-1; RDS read-replica promotion; ECS workload restart in DR region; AWS Backup cross-region restore validation; payment transaction reconciliation post-failover	Semi-annual	RTO ≤ 1h; RPO ≤ 5 min achieved and evidenced
BCP Tabletop	AWS region total outage scenario; crisis escalation; BaFin Art. 19 notification workflow test; manual SEPA batch fallback execution; customer communication	Annual	All decision points executed correctly; notification within 4h
TLPT (TIBER-EU aligned)	Live AWS production environment: payment API, IAM, EC2, ECS, KMS; threat-intelligence-led scope; red-team adversary simulation; blue team (SOC) kept blind; white team oversight	Every 3 years (if designated)	Findings remediated per TIBER-EU framework; supervisory attestation submitted to BaFin

Test Type	AWS Scope	Frequency	Outcome Measure
Backup Restoration Test (AWS Backup)	Full RDS snapshot restore from S3 cross-region backup (eu-west-1); DynamoDB point-in-time recovery; data integrity hash verification; reconciliation against transaction log	Quarterly	100% data integrity; restore completed within RPO (5 min)
Cloud Config Compliance Test	AWS Config managed rules: CIS AWS Foundations Benchmark v2.0; DORA-specific custom rules (encryption, logging, IAM, network isolation); Prowler automated assessment	Monthly	Zero critical non-conformances; 100% rule compliance

8. Five-Step ICT Risk Assessment

Art. 8–13 DORA | ISO 27001:2022 Cl. 6.1 | NIST SP 800-30

Step 1 – Scope Definition

Scope: All AWS ICT assets, processes and third parties supporting the Musterbank cloud-hosted instant payment platform (CIF-REF: MB-CIF-2026-001). Primary region: eu-central-1. DR region: eu-west-1. Exclusions: front-end mobile banking app (separate risk assessment, R-009 in Risk Register); back-office GL system (not in payment processing chain).

Step 2 – Identify Threats and Vulnerabilities

Threat	AWS-Specific Vulnerability	Category
Ransomware / destructive malware	EC2 admin workstation endpoint controls incomplete; EBS snapshots not immutable by default; S3 Object Lock not applied to all buckets	Cyber
AWS region outage (CSP failure)	Active/passive architecture only (not active/active); Route 53 failover adds 15-min latency; single-region primary dependency	Availability
Insider threat / privileged abuse	CyberArk PAM at 88% coverage; 2 shared IAM admin accounts outstanding; IAM Access Analyzer not enforced on all accounts	Human
API injection / business logic abuse	API Gateway WAF rule set partially deployed; schema validation not yet enforced on all endpoints; DAST pipeline coverage 74%	Cyber
Data breach / exfiltration	Payment data present in non-encrypted dev/test environments (S3 buckets); data masking remediation in progress	Data Protection
AWS sub-processor compromise	Limited visibility into AWS CDN/DNS sub-processor security posture; fourth-party risk assessment not completed	Third-Party
IAM misconfiguration	Overly permissive IAM policies detected in Security Hub (remediation in progress); S3 bucket ACLs not uniformly disabled	Cyber

Step 3 – Assess Likelihood and Impact (Rating: 1–5 Low | 6–10 Medium | 11–15 High | 16–25 Critical)

Risk Scenario	Likelihood (1–5)	Impact (1–5)	Gross Risk Score	Rating
AWS region outage — payment unavailability	4	5	20	Critical
Ransomware encrypting AWS payment database	3	5	15	High
Data breach of payment records (dev/test gap)	3	5	15	High
API abuse / fraudulent transaction injection	3	4	12	High
IAM misconfiguration / privilege escalation	3	4	12	High
Insider privilege abuse	2	4	8	Medium
AWS sub-processor compromise	2	4	8	Medium

Step 4 – Evaluate Controls and Residual Risk (CE Scale: 0%=None | 25%=Weak | 50%=Partial | 75%=Effective | 90%=Strong | 95%=Optimised)

Risk Scenario	Key AWS Controls Applied	CE (%)	Residual Score	Rating
AWS region outage	Route 53 active/passive failover; DR in eu-west-1; semi-annual DR test; RTO 1h validated	50%	10	Medium
Ransomware	EDR on admin workstations; S3 Object Lock (immutable); AWS Backup cross-region; IR runbook; GuardDuty	75%	4	Low
Data breach (dev/test)	Encryption at rest (SSE-KMS); dev/test data masking in progress (partial gap — TREAT item)	50%	8	Medium

API abuse	WAF deployed; schema validation pre-go-live; DAST (74% coverage — pre-go-live target ≥90%)	50%	6	Medium
IAM misconfiguration	IAM Access Analyzer; Security Hub; Config rules; CyberArk PAM (88%); quarterly recertification	75%	3	Low
Insider abuse	PAM full deployment by go-live; CloudTrail immutable logs; quarterly access reviews	75%	2	Low
Sub-processor compromise	AWS DPA sub-processor list; 30-day notification; audit rights in contract	25%	6	Medium

Step 5 – Decision Against Board-Approved ICT Risk Appetite

Musterbank's Board-approved ICT Risk Appetite Statement (reviewed annually by the Risk Committee under DORA Art. 5) defines the following thresholds for CIF-supporting systems. Risk ratings use the scale: 1–5 Low | 6–10 Medium | 11–15 High | 16–25 Critical.

Appetite Dimension	Threshold	Risk Scenario	Residual vs Appetite	Decision
Availability	Max outage 1h; 99.95% uptime	AWS region outage	Residual 10 (Medium) — RTO 1h, DR tested; active-active not yet deployed	TREAT — pre-go-live DR validation required
Cyber resilience	No critical finding unmitigated > 30 days	Ransomware / API abuse	Ransomware: residual 4 (Low). API WAF: borderline — pre-go-live remediation required	TREAT — pre-go-live control required
Data protection	No unencrypted sensitive data in non-prod	Data breach	Dev/test masking in progress; partial gap remains	TREAT — deadline before go-live
Third-party	CTPP must hold ISO 27001 / SOC 2; exit plan documented	Sub-processor compromise	AWS certified; sub-processor review pending; exit plan Phase 1 only — concentration risk declared	ACCEPT with enhanced monitoring
IAM / Access	Zero shared admin accounts; PAM 100%	IAM misconfiguration / insider abuse	2 shared admins outstanding; PAM 88% — must reach 100% before go-live	TREAT — pre-go-live mandatory

Go/No-Go Recommendation: The platform should NOT be promoted to production until the following TREAT items are closed and evidenced: (1) API Gateway WAF full deployment and DAST coverage ≥90%; (2) dev/test payment data masking complete — no unencrypted PII/payment data in non-production S3 buckets; (3) PAM coverage 100% and zero shared IAM admin accounts; (4) AWS region DR failover test passed (RTO ≤1h / RPO ≤5min). Consistent with DORA Art. 6(5): the ICT risk management framework must be in place before deploying a CIF. Go-live sign-off gate chaired by CRO with IT Risk and Business sign-off.

Executive Conclusion & Go-Live Checklist

The AWS-hosted instant payment platform is a formally classified CIF (MB-CIF-2026-001). All eight DORA framework requirements have been addressed. Four pre-go-live TREAT items must be closed before production promotion. Findings are consistent with the Musterbank ICT Risk Register (June 2026) and DORA Gap Analysis (June 2026).

#	DORA / Regulatory Obligation	Status
1	CIF classification documented and board-approved; Auslagerungsregister updated (Art. 6, §25b KWG)	COMPLETE
2	ICT Asset Inventory complete with AWS service mapping; linked to Register of Information (Art. 8, ITS #8)	COMPLETE
3	Protective controls deployed: network isolation, cryptography, logging — PAM 88%; DAST 74% (Art. 9–10 BAIT §6–§8)	PARTIAL — PAM 100% and DAST ≥90% required before go-live
4	BIA conducted; RTO 1h / RPO 5min / MTPD 4h board-approved and anchored to SEPA Instant rules (Art. 11)	COMPLETE
5	BCP and DRP documented; AWS eu-central-1 → eu-west-1 failover designed; DR test pending (Art. 11 BAIT §9)	PARTIAL — DR failover test must pass before go-live
6	AWS CTPP risk managed: Art. 30 all 8 mandatory clauses verified; sub-processor chain documented; concentration risk declared to BaFin (Art. 28–30 §25b KWG RTS #7, #9)	COMPLETE
7	AWS in DORT programme: vulnerability assessment (Inspector), pen test, DR test, BCP tabletop, TLPT scoped (Art. 24–27)	COMPLETE — first annual test cycle scheduled
8	Five-step ICT risk assessment completed; 3 TREAT items outstanding (Art. 8–13)	PARTIAL — TREAT items must be closed before go-live
9	Register of Information submitted to BaFin per EBA ITS RTS template (Art. 28(3), ITS Mandate #8)	COMPLETE
10	AWS concentration risk formally declared; multi-cloud roadmap initiated; Azure EU pilot Q3 2026; target ≤55% by 2027 (Art. 29, R-003)	COMPLETE — ongoing mitigation

Musterbank GmbH (fictional entity for portfolio purposes) | DORA Capstone – ICT Risk Management Professional | Prepared by: Shingirai Marenga | ISO 27001 Lead Auditor | CISM | CISSP | June 2026 | Consistent with: Musterbank ICT Risk Register v4 (June 2026) and DORA Gap Analysis v2 (June 2026)